

Remediations

The above section gives an overview of strategies that can be implemented to address exploitable vulnerabilities of the target machine addressed in the methodology section.

I. Short-term Remediations

These are high-priority actions that address specific vulnerabilities exploited in the target machine.

- **Close unnecessary ports:** All ports currently not in use should be closed to shrink the attack surface that can be exploited to gain unauthorized access to system or resources.
- **Prevention of privilege escalation via principal of least privilege:** This can be implemented by removing write access for non-root users on sensitive scripts to ensure that only a root user can modify it, while other users can only read or execute it.
- **Disable Dangerous HTTP Methods:** Turn off the PUT, DELETE, and OPTIONS methods on the web server unless they are strictly required for the application to function.

II. Medium-Term Remediations

These involve changing how the system and its users operate to prevent similar attacks in the future.

- **Strict File Validation:** If file uploads are necessary ensure that only authenticated users have the permission to upload files. And do configure the server to only permit safe, expected file extensions (like .jpg or .pdf) and completely reject executable scripts (like .php).
- **Isolate Uploads:** Store uploaded files outside of the main web root directory so that they cannot be accessed directly via a URL. If they must be in the web root, configure the web server to block the execution of any scripts within the directory where uploaded files are stored.
- **Secure unreferenced directories/files:** All unlinked files/directories not visible on the main website should be behind a secure authentication mechanism (e.g. login portal) to prevent unauthorized access to system.

III. Long-Term Remediations

These are structural changes that ensure the system remains resilient over time.

- **Use of strong encryption schemes:** Any entries on the system should be encrypted such that if even attacker gains unauthorized access to the system, they do not easily gain read access to crucial data like directory listing or crucial notes.
- **Use of Intrusion Detection Systems/Intrusion Detection and Prevention Systems:** The use of Intrusion Detection (and Prevention) Systems is one of the most effective ways to create a centralized system that alerts administrators of suspicious activity like repeated login attempts, suspicious file download activity, and port scanning to allow for a faster response to future incidents.